CS205 Final Term Quick Notes

1. SDLC Phases

Q: Name the 4 main phases of SDLC?

A: Governance, Construction, Employment, Verification.

Q: What happens in Verification phase?

A: Testing to ensure the system works as required before release.

Q: What is Deployment?

A: Delivering and installing the system in the real environment.

2. CIS Controls / DISA STIGs

Q: What are CIS/DISA STIGs for?

A: For security hardening and ensuring safe system configurations.

3. Failure of Information Security Systems

Q: Main reason for failure?

A: Weak governance, no awareness, poor monitoring, and no regular reviews.

4. Security Engineering Activities

Q: Types of activities?

A:

1. Requirements Analysis - find security needs.
2. Design - add security in system design.
3. Implementation & Verification - test and check for security issues.

5. ISO Clauses

Q: Clause 5 in ISO 27001?

A: Leadership - top management's role in security.

Q: Clause 7 in ISO 27001?

A: Support - resources, awareness, communication, documentation.

6. Anthem Security Breach

Q: What caused it?

A: Poor access controls and weak database security.

7. Cyber Security Maturity Model (CSMM)

Q: Layers in order?

A:

1. Foundation - basic security in place.
2. Fundamental - documented policies.
3. Hardened - strong controls and monitoring.
4. Advanced - proactive threat management.

CS205 Final Term Quick Notes

5. Dynamic - continuous improvement.

8. Vulnerability Scanners

Q: Free Qualys tools?

A: Qualys BrowserCheck, Qualys FreeScan.

Q: Which scanner is used for both code & secure configuration vulnerabilities?

A: Nessus.

Q: Steps of scanning (2nd step)?

A: Discover -> Assess -> Report -> Remediate -> Verify.

9. Vulnerability Management (VM) Steps

Q: Name the steps.

A: Discover, Assess, Report, Remediate, Verify.

10. Governance Block Order Example

Q: Arrange these: Awareness (Int), Monitoring (Int), Policy (Init), Periodic Review (Init).

A: Policy (Initial) -> Periodic Review (Initial) -> Awareness (Intermediate) -> Monitoring (Intermediate).

11. Exploits

Q: Remote exploit?

A: Attack from outside the system.

Q: Local exploit?

A: Attack from inside or with local access.

12. Secure Browsers & Email Clients

Q: Which should be used in organizations?

A: Fully supported, latest version, Microsoft browser & email client.